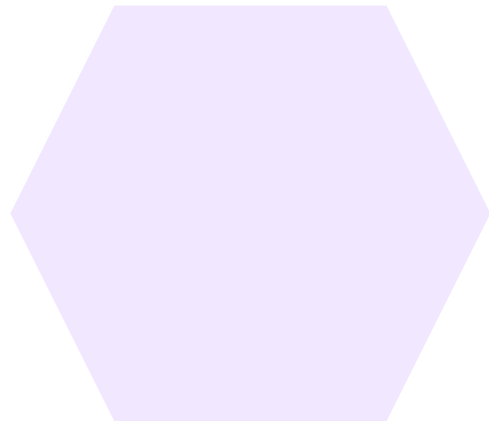




GOVERNANÇA DE IA

QUANDO TODO MUNDO PODE ACESSAR TUDO

Pontos de atenção para times de software em 2026





PARTE 01

O CENÁRIO

O que está acontecendo dentro das empresas agora





OS NÚMEROS DE 2026

24%

das empresas

têm visibilidade dos agentes de IA em uso

37

agentes em média

rodando por organização, a maioria sem auditoria

47%

sem controles

específicos de segurança para IA hoje

Fonte: Gravitee 2026, Kiteworks, BeyondScale



O QUE JÁ ESTÁ NA SUA EMPRESA

01

Devs instalando MCPs sem revisão de segurança

02

Agentes acessando data lake com credenciais herdadas

03

Skills e ferramentas conectadas a APIs internas sem auditoria

04

Prompts com dados sensíveis indo para LLMs públicos

05

Ninguém sabe qual agente fez o quê, nem como parar



PARTE 02

5 FOCOS

Por onde times de software devem começar





IDENTIDADE PARA AGENTES

01

Pare de tratar agente como service account

Cada agente precisa de identidade própria, dono humano, lifecycle e kill switch.

- Quem é o humano responsável por esse agente?
- Que escopo ele tem? Por quanto tempo? Com que dados?
- Como eu paro ele agora se algo der errado?



AI / MCP GATEWAY

02

Tudo passa por um ponto central

Sem isso, você não vê nem controla. É a camada que vira padrão de mercado em 2026.

- Autenticação centralizada (sem API keys soltas)
- Logging imutável de prompts, respostas e tool calls
- Policy enforcement: redação de PII, rate limits, allowlist



ENFORCEMENT EM RUNTIME

03

Decida no momento da chamada

Permissões estáticas falham. O contexto da chamada importa: quem, quando, com que dado.

- Intercepte a invocação da ferramenta antes da execução
- Avalie política com contexto: identidade + dado + ação
- Negue, mascare ou pause em segundos, não em horas



DLP SEMÂNTICO PARA IA

04

Bloquear domínio não basta

O risco não é o canal, é o conteúdo. Classifique o dado antes de proteger.

- Classifique dados por sensibilidade (público, interno, restrito)
- Inspeção semanticamente prompts e respostas, não só URLs
- Mascare PII e segredos antes do dado sair do perímetro



GOVERNANCE VS CONTAINMENT

05

Ver não basta, precisa parar

A maioria monitora agentes mas não consegue interromper quando algo dá errado.

- Kill switch por agente, por usuário, por ferramenta
- Suspensão deve propagar em segundos, não em deploys
- Teste o procedimento. Ninguém quer descobrir que não funciona no incidente



PARTE 03

DECISÕES

0 que pensar antes de sair construindo





BUILD VS BUY E ONDE CONTROLAR

BUILD VS BUY

0 espaço está se profissionalizando rápido.

- Construir do zero: caro, demora, você reinventa
- Comprar: MintMCP, Truefoundry, Cequence, Astrix
- Híbrido: gateway pronto + políticas in-house

ONDE CONTROLAR

Três camadas, escolha pelo menos uma.

- Gateway de API: centralizado, vira gargalo
- Browser corporativo: ponto de interação
- Endpoint: granular, mais complexo



POR ONDE COMEÇAR ESSA SEMANA

01

INVENTÁRIO

Liste todo MCP, agente e ferramenta de IA em uso. Sem isso, qualquer plano é chute.

02

GATEWAY

Coloque tudo atrás de um ponto de saída. Logging primeiro, policy depois.

03

KILL SWITCH

Garanta que você consegue parar um agente em segundos. Teste antes de precisar.

PRINCÍPIO

VOCÊ NÃO GOVERNA O QUE NÃO VÊ.

Comece pelo inventário, passe tudo por um gateway, garanta que você consegue parar. Esse é o mínimo viável de governança de IA em 2026.

OBRIGADO

